信息安全与数据分级管理制度

文档编号：保留原制度编号与版本 | 归口部门：技术部信息安全组；入库范围：公司公共；可见范围：本公司已授权员工。 | 状态：现行

文档信息

文档编号	XH-SEC-2026-02	版本	3.0
归口部门	技术部信息安全组	批准角色	总经理办公会
生效日期	2026年7月1日	复审日期	2027年6月30日
适用范围	公司全体员工及经授权的外部协作人员	密级	内部使用

适用说明

本制度建立数据分类、访问控制、外发、留存和事件报告要求。数据所有者负责确定业务分类，信息安全团队负责控制基线与审计，所有接触公司数据的人员均须遵守最小权限原则。

1 数据分级

级别	典型示例	访问与传输要求	默认保留期
公开	官网内容、已发布白皮书、公开职位信息	可公开传播；发布前仍需内容审核	按业务需要
内部	一般流程、内部通讯录、培训材料	仅限员工和获批协作方；外发需业务负责人批准	3年
机密	客户合同、未发布财务数据、源代码、漏洞详情	基于角色授权；传输与存储加密；外发需数据所有者批准	合同结束后5年或制度另有规定
严格机密	生产密钥、身份证件、银行卡信息、批量个人数据	实名授权、强认证、全程审计；禁止通过普通邮件和公共网盘传输	达到目的后尽快删除，最长依适用要求

2 访问控制

访问权限由岗位需要决定，申请须说明系统、权限级别、期限和业务理由。

机密及严格机密数据的访问至少每季度复核一次；离职、转岗或项目结束时应在4小时内撤销不再需要的权限。

管理员账号不得用于日常办公；高权限操作应使用独立账号并保留审计记录。

共享账号原则上禁止。无法避免时，系统负责人必须启用凭据托管、使用审批和操作追踪。

3 数据传输与外部服务

机密和严格机密数据传输必须使用公司批准的加密通道。向客户、供应商或其他外部主体提供数据前，应确认合同依据、接收范围、保存期限和删除方式。不得将客户数据、源代码、密钥、未公开合同或个人敏感信息输入未经公司批准的生成式人工智能、翻译、文件转换或在线调试服务。

经批准使用外部人工智能服务时，应优先使用企业账号，关闭模型训练或内容留存选项，并对输入内容执行最小化和脱敏。公开数据可以直接使用；内部数据须经部门负责人批准；机密及严格机密数据原则上禁止输入，确需使用时须经数据所有者和信息安全负责人书面批准。

4 终端和凭据安全

控制项	最低要求
身份认证	公司核心系统启用多因素认证；密码不得在个人与公司账户间复用。
终端保护	公司终端启用磁盘加密、自动锁屏和终端检测；禁止擅自关闭安全软件。
密钥管理	API密钥和生产凭据存入批准的密钥系统，不得写入代码、工单或聊天记录。
补丁更新	互联网暴露系统的严重漏洞原则上72小时内修复，高危漏洞7日内修复。

5 安全事件报告

发现账号异常、数据误发、设备遗失、恶意软件、密钥泄露或疑似未授权访问时，应立即停止可能扩大影响的操作，并在30分钟内通过安全热线或事件系统报告。报告应包含发现时间、涉及系统、数据范围、已采取措施和联系人。未经授权不得自行删除日志、联系攻击者或对外发布信息。

6 数据删除和介质处置

数据达到保留期限或处理目的结束后，由数据所有者发起删除。生产数据删除应覆盖主存储、可操作副本和已到期备份；无法立即从不可变备份删除的，应限制访问并在备份自然轮换时清除。纸质机密材料使用保密销毁服务，存储介质复用或报废前执行经验证的安全擦除。

7 违规处理

违反本制度将根据影响范围、主观过错、补救配合和重复发生情况处理。善意、及时报告自身误操作的人员不会仅因报告行为受到报复，但故意隐瞒、绕过控制或未经授权传播数据将从重处理。